

Лекция 7. Современные вызовы информационной безопасности

Введение

Сегодня мы наблюдаем беспрецедентное ускорение эволюции киберугроз. Информационная безопасность перестала быть локальной задачей ИТ-отделов – это часть стратегии выживания бизнеса, элемент государственной стабильности и личной безопасности граждан.

Если ещё несколько лет назад ИБ ассоциировалась в основном с вирусами и одиночными хакерами, то теперь это сложная экосистема, включающая государственные структуры, криминальные группировки, коммерциализированные сервисы и технологии нового поколения.

ENISA, Forescout, Kaspersky и PT Security отмечают: мы вступили в период, когда угрозы становятся не только массовыми, но и системными.

Современный мир цифровизируется быстрее, чем успевают адаптироваться механизмы защиты.

Объём цифровых данных растёт экспоненциально, а зависимость от облаков, SaaS-сервисов и цепочек поставок делает безопасность не только техническим, но и управленческим вызовом.

1. Глобальные тенденции киберугроз

1.1 Преступность как услуга

Глобальные тенденции последних лет показывают рост зрелости киберпреступности.

Появились модели «атака как услуга» (**Malware-as-a-Service, MaaS**), где любой желающий может купить готовый набор инструментов: вредоносы, фишинговые кампании, эксплойты.

Эти сервисы работают как полноценные ИТ-компании – с техподдержкой, обновлениями, программами лояльности и даже системой скидок для «постоянных клиентов».

Различные платформы продают подписку на доступ к инфраструктуре атак.

Таким образом, преступность превращается в распределённую экосистему, где производители, операторы и покупатели вредоносных инструментов действуют как партнёры.

Рынок MaaS стал одной из ключевых причин увеличения числа инцидентов: злоумышленникам больше не нужно разрабатывать вредоносный код – достаточно купить готовый набор.

1.2 Атаки на цепочки поставок

Параллельно растёт количество атак на цепочки поставок (**supply chain attacks**).

Компрометация одной библиотеки или подрядчика может привести к взлому десятков организаций.

Современное программное обеспечение состоит из тысяч зависимостей и внешних пакетов – уязвимость даже одного модуля может иметь лавинообразный эффект.

Forescout прогнозирует: к 2026 году почти треть всех новых уязвимостей будет связана с сетевой инфраструктурой и цепочками поставок.

Примером может служить компрометация пакетов в PyPI и NPM – такие инциденты происходят регулярно, а последствия затрагивают тысячи разработчиков.

1.3 Роль государства и геополитика

Кибербезопасность стала не только технологическим, но и стратегическим направлением государственной политики.

Современные кибератаки всё чаще носят **гибридный** характер: они пересекаются с экономическими санкциями, шпионажем и геополитическими интересами.

АРТ-группы действуют как военные подразделения – с бюджетами, инфраструктурой и разведкой.

Кибероперации против инфраструктур (энергетика, транспорт, медицина) становятся частью стратегии давления.

Россия активно развивает и внедряет различные меры, нацеленные на предотвращение кибератак и киберугроз.

Основные меры, реализуемые в России:

1. **Развитие национальной инфраструктуры доверия.**

Созданы отечественные центры обработки данных, криптографические сервисы, сертифицированные алгоритмы шифрования (ГОСТ Р 34.12-2015 «Кузнечик», ГОСТ Р 34.10-2012 ЭЦП).

Активно развивается система отечественных сертифицированных средств защиты, включая отечественные ОС (Astra Linux, РЕД ОС), системы мониторинга и SIEM-платформы.

2. **Создание централизованной системы мониторинга инцидентов.**

Главным координатором является **Национальный координационный центр по компьютерным инцидентам (НКЦКИ, ФСБ РФ)**.

Центр обеспечивает обмен информацией между государственными и коммерческими структурами, координирует реагирование и предупреждение атак, включая международные уведомления через CERT-сети.

3. **Развитие нормативно-правовой базы.**

Приняты федеральные законы № 187-ФЗ «О безопасности критической информационной инфраструктуры» (КИИ) и № 152-ФЗ «О персональных данных». Эти документы закрепляют обязательные меры защиты КИИ, аудит безопасности и ответственность за нарушение требований.

4. **Импортонезависимость и суверенные технологии.**

Россия последовательно снижает зависимость от зарубежного ПО, создавая национальные реестры отечественных решений.

Развивается проект «ГосТех», объединяющий сервисы госуправления на единой защищённой платформе.

5. **Кадровая и образовательная политика.**

Программы подготовки специалистов реализуются в рамках проектов

«Кибергигиена», «Цифровая экономика», федеральных центров компетенций.

На базе вузов формируются **Центры киберустойчивости и CTF-платформы** для практического обучения специалистов.

6. **Геополитический аспект.**

Россия участвует в международных рабочих группах по вопросам ИБ под эгидой

ООН, БРИКС и ШОС.

Активно продвигается концепция «**суверенного интернета**», предусматривающая автономное функционирование российских сегментов сети в случае глобальных сбоев или атак.

Эти меры направлены на снижение зависимости от зарубежных поставщиков, укрепление технологического суверенитета и формирование национальной киберустойчивости.

2. Индустриализация киберпреступности

Киберпреступность эволюционирует от единичных инцидентов к массовым сервисам. Появились специализированные «биржи доступа», где можно купить учетные записи, базы данных или администраторские токены.

Злоумышленники предлагают гарантии и отзывы – как на обычных маркетплейсах.

Пример: в 2025 году на даркнет-форуме DarkLeak был зафиксирован «рейтинг исполнителей» для атак по заказу.

Некоторые сервисы предоставляют панели мониторинга, отчёты о выполнении задач и даже SLA – аналог соглашений об уровне сервиса.

Спрос рождает предложение, и рынок Maas растёт быстрее, чем рынок антивирусов. Это делает борьбу с киберпреступностью задачей международного уровня, требующей скоординированных действий.

3. Искусственный интеллект в кибератаках

3.1 Новые инструменты

Искусственный интеллект стал **катализатором эволюции атак**.

Генеративные модели помогают злоумышленникам создавать реалистичные фишинговые письма, имитировать голоса и лица руководителей, генерировать вредоносный код и даже разрабатывать самообучающиеся вредоносы.

Появились известные примеры: **WormGPT, FraudGPT, DarkBART** – платные модификации языковых моделей, оптимизированные для создания атак.

Они генерируют фишинг-тексты без орфографических ошибок, подделывают переписку, имитируют стиль корпоративных сообщений.

ИИ-вредоносы уже способны **адаптироваться**: анализировать реакции антивирусов, менять тактику, модифицировать код во время работы.

DeepFake-технологии усиливают социальную инженерию, делая её практически неотличимой от реального взаимодействия.

3.2 Пример: синтетическая личность

Синтетические личности – это образы людей, созданные с помощью генеративных нейросетей (видео, аудио, 3D-аватары).

Они используются злоумышленниками для **мошенничества, шантажа и атак на доверие**.

Реальный пример (2024 г., Гонконг).

В феврале 2024 года компания Agur (международный инженерный холдинг) сообщила об инциденте, когда финансовый сотрудник участвовал в видеоконференции с «руководством» – на экране были DeepFake-аватары коллег.

ИИ-система сгенерировала лица и голоса в реальном времени, используя открытые видео из интернета.

Сотрудник, не подозревая подделку, перевёл мошенникам **около 25 млн долларов** на указанные счета.

Эта атака стала первой подтверждённой масштабной операцией с использованием **группового DeepFake-видеозвонка**, полностью имитировавшего встречу в Teams.

Позже расследование показало, что злоумышленники использовали комбинацию нейросетей DeepFace Lab и VALL-E для синтеза голоса.

Мошенники имели предварительные данные о переговорах компании – классическая атака на основе социальной инженерии + ИИ.

Подобные случаи в России

В 2025 году зафиксировано несколько случаев звонков от «руководителей банков» с генерированным голосом.

По данным ЦБ РФ, в 70 % случаев такие атаки использовали реальные записи публичных речей.

Банк России совместно с Минцифры внедряет систему **аудио-верификации и детектирования DeepFake-голоса** при обработке обращений клиентов.

Синтетические личности стали новым уровнем атак на доверие, и защита от них требует применения алгоритмов анализа микровибраций голоса, морфологии лица и паттернов движений.

ИИ стал не только инструментом нападения, но и объектом защиты: появляются решения для обнаружения «ИИ-угроз» и проверки контента на подделку.

4. Угрозы цепочек поставок и экосистем разработки

Одной из наиболее серьёзных проблем остаются атаки на цепочки поставок ПО и инструменты разработчиков.

Компрометация даже небольшой зависимости может привести к массовому заражению.

4.1 Кейс VS Code: вредоносное расширение «Material Icon Theme»

Недавний пример, описанный **Nextron Systems** (28 ноября 2025 г.), – вредоносное расширение для Visual Studio Code, выдававшее себя за популярную тему «Material Icon Theme».

Расширение содержало два импланта на Rust (для Mach-O и Windows PE), что позволяло закрепляться в разных операционных системах.

Внутри обнаружены обфусцированные скрипты JavaScript и встроенные бинарные модули.

Инцидент подчеркнул: даже легитимные площадки, такие как VS Code Marketplace, могут стать вектором вторжения.

Обычные антивирусы не обнаруживали угрозу из-за обфускации и «чистого» поведения на поверхности.

Microsoft оперативно удалила расширение, но до этого оно успело установиться более чем 16 000 раз.

Этот пример наглядно показывает, почему нужен многоуровневый контроль артефактов и систем доставки ПО.

4.2 Кейс GlassWorm – самораспространяющийся вредонос

Ранее исследователи Truesec и BleepingComputer зафиксировали вредонос **GlassWorm**, который внедрялся в расширения VS Code и OpenVSX.

Он использовал невидимые символы Unicode для маскировки кода, похищал учётные данные GitHub и npm, устанавливал бэкдоры.

GlassWorm мог самостоятельно заражать другие расширения через цепочки зависимостей, создавая эффект самораспространения.

4.3 Выводы для разработчиков

Даже инструменты, предназначенные для повышения производительности, могут стать вектором атаки.

Компании должны внедрять процедуры проверки всех расширений, пакетов и дополнений перед установкой.

Необходим аудит и сканирование артефактов, использование песочниц и систем обнаружения аномалий.

5. Квантовые и постквантовые риски

Квантовые вычисления открывают новую эру в развитии технологий – и новый уровень угроз.

Квантовый компьютер способен выполнять параллельные вычисления, что делает возможным взлом классических алгоритмов шифрования (RSA, ECC, DSA).

Атака по алгоритму Шора теоретически позволяет расшифровать RSA-2048 за часы при наличии квантового компьютера с несколькими миллионами кубитов.

Такие системы пока не доступны, но их появление – лишь вопрос времени.

Пример 1. Риск «Собери сейчас – расшифруй позже» (Harvest Now, Decrypt Later)

Многие хакерские группы и разведслужбы уже сегодня перехватывают зашифрованные данные, чтобы хранить их до появления квантовых вычислительных мощностей.

Это особенно опасно для долгосрочно конфиденциальной информации – переписки госорганов, архивов, медицинских данных, военных документов.

ENISA называет такие атаки «тихими инвестициями в будущее взлома».

Пример 2. Миграция к постквантовым алгоритмам

В 2024 году NIST (США) и ENISA (ЕС) утвердили стандартные кандидаты на постквантовые алгоритмы:

- **CRYSTALS-Kyber** (шифрование и обмен ключами);
 - **CRYSTALS-Dilithium, FALCON** и **SPHINCS+** (электронная подпись).
- Компании Google, Cloudflare, IBM уже начали их тестирование в своих продуктах. Россия также проводит исследования: ФСТЭК и Минцифры координируют проект

«Постквантовая криптография РФ», а Росатом и ИТМО занимаются разработкой отечественных аналогов Kyber и Dilithium.

Пример 3. Риски квантовых симуляторов

Квантовые симуляторы уже используются в исследовательских лабораториях (IBM Quantum, Alibaba Cloud Quantum Lab).

В 2025 году исследователи IBM продемонстрировали взлом 48-битного RSA-ключа на гибридной системе с 433-кубитным процессором «Condor».

Хотя до реального взлома RSA-2048 ещё далеко, факт успешного применения гибридных квантово-классических подходов подтверждает приближение новой эпохи криптоугроз.

Меры реагирования

1. Разработка национальных криптографических стандартов, устойчивых к квантовым атакам (ГОСТ П-КУЗНЕЧИК-Q, ГОСТ 34.13-Q).
2. Аудит жизненного цикла ключей и сертификатов – особенно в долгосрочных системах (банковские и госархивы).
3. Создание тестовых стендов для перехода на PQC (постквантовая криптография) в сфере КИИ.
4. Международное сотрудничество – Россия участвует в экспертных группах БРИКС по развитию квантовой коммуникации и разработке защищённых протоколов.

6. Человеческий фактор и организационная культура

При всём технологическом развитии именно человек остаётся слабым звеном.

80 % инцидентов начинается с ошибки пользователя – фишинг, неосторожность, неверное использование доступа.

Социальная инженерия становится всё более психологически точной и грамотной.

Zero Trust – ключевой принцип современной защиты.

Он предполагает, что не доверяют ни пользователям, ни устройствам, ни сетям без дополнительной проверки.

Регулярное обучение, тестирование, симуляции фишинга и повышение осведомлённости становятся обязательной частью культуры безопасности.

7. Практика инцидентов и расследований

PT Security в 2024–2025 гг. провела более 100 расследований, почти половина из них связана с АРТ-группами. В категории Cybercrime объединены атаки, направленные преимущественно на совершение деструктивных действий (шифрование, уничтожение) в отношении информации и бизнес-процессов компаний.

Важно отметить, что однозначно идентифицировать атакующих не всегда представляется возможным. Так, в 26% компаний были выявлены следы публично не идентифицированных злоумышленников

Средняя длительность инцидента – 9 дней, но отдельные атаки оставались незамеченными до 3 лет.

Основные векторы – бизнес-приложения, подрядчики и доверенные сети.

Это доказывает, что даже зрелые организации не всегда готовы к комплексным угрозам.

8. Заключение: адаптивная безопасность

Кибербезопасность уже не ограничивается технологиями.

Это философия и система ценностей, встроенная в корпоративную культуру.

Адаптивность, сегментация, видимость активов, обновление криптографии и обучение персонала – фундамент современной защиты.

В мире, где киберпреступность стала индустрией, только системный подход и постоянная адаптация способны минимизировать ущерб и обеспечить устойчивость организаций.

Источники и аналитика

- **ENISA Threat Landscape 2025** – www.enisa.europa.eu
- **Forescout Research Labs, Cybersecurity Forecast 2025** – www.forescout.com
- **Kaspersky Security Bulletin 2025** – www.kaspersky.com
- **PT Security Trends 2025** – www.ptsecurity.com
- **Nextron Systems Blog, 28 Nov 2025: *Malicious VS Code Extension Impersonating “Material Icon Theme”***
- **Truesec Report: *GlassWorm Self-Propagating Malware in VS Code and OpenVSX***
- **BleepingComputer News: *VS Code Extensions Pulled Over Security Risks, 2025***